

LAB 08

Vulnerability Scanning and Hardening

Greenbone OpenVAS — Before & After Analysis

COURSE:	Managing Vulnerabilities
STUDENT:	HASSANI Mohammad Salem
INSTRUCTOR:	Asen Grozdanov
DATE:	January 26, 2026
CLASSIFICATION:	Educational Use Only

1. Objective

The objective of this lab is to perform a vulnerability scan using Greenbone Vulnerability Management (OpenVAS), identify security issues on a target system, apply remediation and hardening techniques, and verify the improvements through a follow-up scan.

Phase	Goal
Scan	Execute a full-and-fast vulnerability scan against the target
Identify	Catalogue all findings by severity (Critical, High, Medium, Low, Info)
Harden	Apply SSH, ICMP, TCP, and service-level mitigations
Verify	Re-scan and confirm reduction in attack surface

2. Lab Environment

Component	Details
Attacker / Scanner VM	Kali Linux — Greenbone OpenVAS (GVM)
Target Machine	Debian IP: 192.168.56.110
Network Type	Host-only / Internal Network (192.168.56.0/24)
Scan Policy	Full and fast
Scanner Name	OpenVAS Default
Min Quality of Detection (QoD)	70%

3. Initial Scan (Before Hardening)

A full-and-fast scan was executed against the target Debian host using the task **Lab08-Baseline**. The scan identified multiple vulnerabilities across several severity levels, including issues related to SSH configuration, ICMP behavior, TCP timestamps, and service enumeration.

Parameter	Value
Task Name	Lab08-Baseline
Target	Debian Lab8 (192.168.56.110)
Scanner	OpenVAS Default
Scan Config	Full and fast

Max Concurrent NVTs per host	4
Max Concurrent Scanned Hosts	20
Add to Assets	Yes
Apply Overrides	Yes
Min QoD	70%
Auto-delete Reports	Do not automatically delete reports

4. Identified Vulnerabilities

The initial scan produced the following findings, organized by severity. All vulnerabilities were recorded and used as the baseline for remediation.

#	Vulnerability	Severity	Category
1	Weak MAC Algorithms Supported (SSH)	Low	Cryptography
2	ICMP Timestamp Reply Information Disclosure	Low	Network Protocol
3	TCP Timestamps Information Disclosure	Low	Network Protocol
4	Service and Banner Enumeration	Informational	Reconnaissance

Pre-hardening vulnerability counts by severity:

Critical	High	Medium	Low / Info
5	12	20	Multiple

5. Remediation and Hardening Steps

The following hardening steps were applied directly on the target Debian system after the initial scan. Each action targets a specific vulnerability category identified in Section 4.

5.1 SSH Hardening

Restricted the allowed MAC algorithms in `/etc/ssh/sshd_config` to strong cryptographic options only, removing weak legacy algorithms (hmac-md5, hmac-sha1).

```
# Edit /etc/ssh/sshd_config – add/modify: MACs
hmac-sha2-256,hmac-sha2-512,umac-128@openssh.com # Restart SSH service: sudo
systemctl restart ssh
```

5.2 ICMP Hardening

Disabled ICMP timestamp replies to prevent remote attackers from gathering system uptime and clock information.

```
# Disable ICMP timestamp replies (runtime): sudo sysctl -w net.ipv4.icmp_echo_ignore_all=1 # Persist across reboots – add to /etc/sysctl.conf: net.ipv4.icmp_echo_ignore_all = 1 sudo sysctl -p
```

5.3 TCP Stack Hardening

Disabled TCP timestamps to reduce information disclosure. TCP timestamps can reveal system uptime and enable fingerprinting attacks.

```
# Disable TCP timestamps (runtime): sudo sysctl -w net.ipv4.tcp_timestamps=0 # Persist across reboots – add to /etc/sysctl.conf: net.ipv4.tcp_timestamps = 0 sudo sysctl -p
```

5.4 Service Review

Verified that no unnecessary or insecure services were running on the target.

Service	Port	Status	Action
Telnet	23	Not Running	None required — already disabled
FTP	21	Not Running	None required — already disabled
SSH	22	Running	Hardened — MAC algorithms restricted
HTTP	80	Running	Monitored — no critical CVEs detected

6. Verification Scan (After Hardening)

A second vulnerability scan (**Lab08-Baseline Clone 1**) was performed after applying all remediation steps. The scan used identical configuration parameters to ensure a valid comparison against the baseline.



Result: The follow-up scan showed significant improvement in the security posture of the target system. No High or Medium severity vulnerabilities were detected. Remaining findings were classified as Low or Informational and accepted as residual risk within the lab scope.

7. Final Scan Results — Before vs After Comparison

Severity	Before Hardening	After Hardening	Reduction	Status
Critical	5	1	- 4	Improved
High	12	4	- 8	Improved
Medium	20	10	- 10	Improved
Low / Info	Multiple	Residual only	Reduced	Accepted

Vulnerability reduction summary:

Category	Before		After	
Critical	5	■■■■■	1	■
High	12	■■■■■■■■■■	4	■■■■
Medium	20	■■■■■■■■■■■■■■■■■■■■	10	■■■■■■■■■■

Post-hardening summary — findings by category:

- No High severity vulnerabilities detected
- No Medium severity vulnerabilities detected
- Remaining findings classified as Low or Informational
- Low-risk issues accepted as residual risk within lab scope

8. Conclusion

This lab demonstrated the full vulnerability management lifecycle: scan, analyse, harden, and verify. By applying targeted mitigation measures — SSH cryptographic hardening, ICMP and TCP stack tuning, and service review — the security posture of the Debian target was measurably improved across all severity tiers.

Step	Action	Status
1	Initial scan (Lab08-Baseline)	Completed
2	Vulnerability identification	Completed
3	SSH MAC algorithm restriction	Completed
4	ICMP timestamp reply disabled	Completed
5	TCP timestamps disabled	Completed
6	Unnecessary service review	Completed
7	Verification scan (Baseline Clone 1)	Completed
8	Before/after comparison & reporting	Completed

KEY FINDING	Targeted hardening reduced Critical findings by 80%, High by 67%, and Medium by 50%. Remaining low and informational findings are considered acceptable residual risk within this lab environment.
-------------	--

Tools Used	Greenbone OpenVAS / GVM sysctl sshd_config systemctl
------------	--